

Incident Response Plan

SIMULATED / FICTIONAL EVIDENCE — FOR EDUCATIONAL USE ONLY

Organization	CloudFlow Technologies (fictional SaaS vendor)
Product in scope	CloudFlow CRM
Classification	Confidential — Internal Use / Simulated Evidence
Approval status	Approved for simulation (not a live corporate record)
Document owner	Jordan Hale, Chief Information Security Officer
Document ID	IRP-001
Version	2.4
Effective date	01 June 2024
Last review date	15 January 2026
Last tabletop exercise	19 August 2025

1. Purpose

This plan describes how CloudFlow Technologies detects, classifies, contains, eradicates, and recovers from cybersecurity incidents affecting CloudFlow CRM and supporting systems.

2. Incident classification

- Severity 1: confirmed material impact to confidentiality, integrity, or availability of customer production data or a widespread service outage.
- Severity 2: confirmed security event with limited blast radius or degraded service.
- Severity 3: suspected event or policy violation without confirmed customer impact.

3. Detection

Detection sources include SIEM alerts, GuardDuty, WAF events, employee reports, customer reports, and vulnerability intelligence. Security operations triages alerts 24x7 for privileged anomalies.

4. Containment, eradication, recovery

Incident Command is the Director of Security or delegate. Containment may include credential revocation, security-group changes, tenant isolation actions, and traffic blocking. Eradication removes the cause. Recovery restores service from known-good configuration and backups. A lessons-learned review is required for Severity 1 and 2 within 15 business days.

5. Internal escalation

Severity 1 incidents are escalated to the CISO and executive leadership within 24 hours of confirmation.

6. Notification (customer) — current language

CloudFlow will notify affected customers of a material cybersecurity incident without undue delay and as required by applicable law. Named customer security contacts are used where provided. This plan does not currently specify an hour-based customer notification SLA (for example, 24 or 72 hours). Legal and communications maintain internal notice templates; those templates are not appended to this customer-facing excerpt. An assessor should treat the absence of a clock as a contractual and operational gap.

7. Evidence handling

Logs and forensic images are preserved in write-once storage. Chain-of-custody is recorded for Severity 1.